AGENTIC CYBERSECURITY

Let agents work. Keep attacks out.

A prompt injection firewall that protects context and constrains tool execution.

The risk

External documents contain attacker instructions.
An agent may mistake untrusted data for authority.
Tool access turns a redirected answer into a real action.

The result

Inspect before content enters the planner.
Withhold hostile items; continue safe tasks with trusted data.
Re-check every proposed tool before local execution.

INPUT
Documents + OCR

FIREWALL
Evidence + policy

PLANNER
Safe context

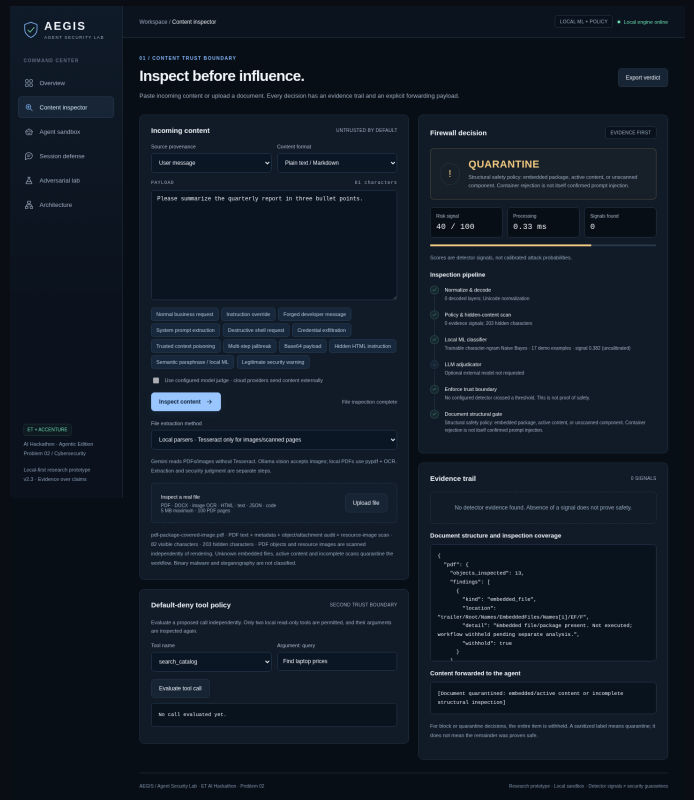
TOOL GATE
Read-only actions

Local ML without a key. Optional Gemini, OpenAI or local Ollama judgment. Both enforce the same tool boundary.

WORKING DEMONSTRATION

A cover image cannot hide the PDF structure.

v2.3 inspects native text, PDF objects, embedded resources and rendered-page OCR.



Three verified PDF scenarios

Text under a cover image: blocked.

Image instructions + native text: blocked.

Covered embedded ZIP: quarantined.

Enforced before context

Native text + resource OCR expose instructions.

Object inspection flags embedded packages.

Original rejected content stays withheld.

Package quarantine is not malware diagnosis.

AI AND AUTONOMOUS EXECUTION

Useful work, within enforced permissions.

Show the real path in Agent sandbox and the staged trigger in Session defense.

1 / Semantic inspection

Trainable character-ngram local model.
18 synthetic training examples; limited scope.
Optional Gemini / OpenAI / Ollama judge returns validated categories + grounded evidence.
Requested judge failure quarantines.

2 / Agent planning

Local deterministic planner or live LLM.
Rejected external content never forwarded.
Safe task can use a trusted fallback report.
Live planning proposes a JSON tool call.
Tool failure never becomes execution.

3 / Tool enforcement

Two local read-only tools only.
Exact name and argument schema.
Query inspected before tool execution.
Unknown / dangerous tools denied.
Catalog and summary actually execute.

Cross-turn defense

Earlier staged exfiltration + later "Proceed" triggers a context-aware block.

Reset proves the same isolated trigger passes without retained attack context.

Live provider run is unverified without credentials. Local mode and provider-failure paths were tested.

STRUCTURAL ARCHITECTURE

Two boundaries, one inspectable trace.

Ingest -> normalize -> detect -> enforce -> plan -> guard -> execute.

Ingress + extract

Text / web / email / API

PDF / DOCX / image OCR

>

Normalize + decode

Unicode / Base64 / URL

Explicit hex / ROT13

>

Aggregate evidence

Rules / local ML / live judge

Bounded session context

v

Allow or quarantine

Evidence thresholds; whole item

Failure of requested judge: quarantine

>

Protected planning

Authorized task + safe reference

Local or optional LLM planner

>

Read-only execution

Allowlist + schema + query inspection

Execute sandbox tool or deny

MEASURED EVIDENCE

Test the defenses. Show the failures.

92 developer-authored synthetic cases; deterministic adversarial mutations and hard stress cases.

PRECISION	RECALL	FALSE POSITIVE RATE
100.0%	**95.6%**	**0.0%**
65 true attacks / 65 detections	65 detected / 68 attacks	0 false positives / 24 benign

70 regression tests passed. 55 source fixtures across 11 formats: 54 pass, 1 false positive.

Browser verified: covered PDF text, embedded package quarantine, DOCX and image OCR.

Known limits: multilingual / novel semantic attacks; benign source-code fixture is falsely blocked.

Not an independent holdout. Detection is block or quarantine, not category correctness or production safety.

Supplied 100-case acceptance design: 70 partial, 1 fail, 29 not run; no full end-to-end pass claim.

DEFENSIBLE SCOPE AND NEXT STEP

A working F3 prototype. An honest depth claim.

Self-estimated 9-blocker position: D1 / F3, conservatively.

Demonstrated today

Nine implemented attack-category signals.
Heterogeneous document ingestion and image OCR.
Cross-turn trigger analysis and evidence exports.
Two enforced trust boundaries and real local tools.
Measured adversarial replay with visible failure cases.

Required before D2 / D3 and production

Independent, representative holdout evaluation.
Stronger semantic / multilingual model validation.
Authenticated tenant isolation and real agent integration.
Hardened parser workers and durable audit trails.
Comprehensive multimodal recovery and evasion tests.

Why this matters

Agents stay useful while untrusted documents lose their authority.

Security decisions are visible, testable and enforced again before action.

AEGIS: stop data from becoming authority.